

RULES OF ENGAGEMENT

Cybersecurity Testing Engagement

1. Document Purpose

This Rules of Engagement (“RoE”) document defines the operational procedures, constraints, communication protocols, and technical parameters for the cybersecurity testing engagement conducted by **Robert Richards Cybersecurity**.

This document supplements the applicable **Services Agreement** and **Authorisation Letter** between the Client and Robert Richards Cybersecurity.

The RoE ensures that all testing activities are conducted in a controlled, authorised, and responsible manner.

2. Engagement Overview

Client Organisation: _____

Testing Provider: Robert Richards Cybersecurity

Project Name / Reference: _____

Project Manager (Client): _____

Project Lead (Tester): Robert Richards

Start Date: _____

End Date: _____

Testing Window: 06:00 - 22:00

3. Scope of Testing

Testing will only be conducted against systems explicitly authorised by the Client.

Authorised Domains

Authorised IP Ranges

Authorised Applications

Authorised APIs / Services

Authorised Cloud Infrastructure

Additional Assets

4. Out-of-Scope Assets

The following systems must **not be tested**:

Testing outside the authorised scope is strictly prohibited.

5. Testing Methodology

Testing activities may include the following techniques where appropriate:

- vulnerability scanning
- manual penetration testing
- application security testing
- network enumeration
- authentication and authorisation testing
- configuration analysis
- exploitation of discovered vulnerabilities for proof-of-concept purposes

Testing is conducted in accordance with recognised industry standards including:

- OWASP Testing Guide
- NIST SP 800-115
- PTES (Penetration Testing Execution Standard)

6. Prohibited Activities

Unless explicitly authorised in writing by the Client, the following activities are **not permitted**:

- Denial-of-Service (DoS) or Distributed DoS testing
- destructive exploitation causing permanent damage
- intentional data destruction
- modification of production data
- social engineering attacks
- phishing campaigns
- physical security testing
- password spraying or brute force attacks against large numbers of accounts

7. Source IP Addresses of Tester

Testing traffic will originate from the following IP addresses:

These addresses should be allow-listed where necessary.

8. Testing Schedule

Testing will occur during the following time period:

06:00 - 22:00

Unless otherwise agreed, testing may occur during normal business hours.

Certain high-risk testing activities may be scheduled outside business hours.

9. Communication and Contact Information

Primary Contact – Client

Name: _____

Role: _____

Phone: _____

Email: _____

Technical Contact – Client

Name: _____

Phone: _____

Email: _____

Testing Contact

Name: Robert Richards

Company: Robert Richards Cybersecurity

Email: robert.k.richards@gmail.com

Phone: 01782689662

10. Incident Handling and Escalation

If testing causes unexpected service disruption, system instability, or other operational issues:

1. testing will be paused immediately
2. the Client's emergency contact will be notified
3. testing will only resume after confirmation from the Client

Emergency Contact: _____

Name: _____

Phone: _____

11. Data Handling and Evidence Collection

During testing, Robert Richards Cybersecurity may collect limited data as proof of vulnerabilities.

This may include:

- screenshots
- configuration information
- proof-of-concept exploit output

Sensitive data will **not be extracted beyond what is necessary to demonstrate the vulnerability.**

All collected data will be handled confidentially.

12. Logging and Monitoring

The Client acknowledges that testing may trigger security alerts within:

- SIEM systems
- intrusion detection systems
- endpoint security solutions
- network monitoring systems

The Client may choose to whitelist tester IP addresses where appropriate.

13. Legal Compliance

Testing is conducted with the explicit authorisation of the Client.

The activities described in this document are authorised security testing under German law and are relevant to the following provisions of the German Criminal Code:

- Strafgesetzbuch §202a
- Strafgesetzbuch §202b
- Strafgesetzbuch §303a
- Strafgesetzbuch §303b

The Client confirms that it has legal authority over the systems being tested.

14. Reporting

Upon completion of testing, the Client will receive a report containing:

- an executive summary
- vulnerability descriptions
- risk ratings
- proof-of-concept evidence
- remediation recommendations

Delivery format:

- ☐ PDF
- ☐ Secure portal
- ☐ Encrypted archive

15. Confidentiality

All findings, vulnerabilities, and system information discovered during testing shall be treated as confidential.

Disclosure to third parties requires written consent from the Client unless required by law.

16. Approval

By signing this document, both parties acknowledge and agree to the Rules of Engagement described herein.

Service Provider

Robert Richards Cybersecurity

Name: Robert Richards

Location: <location>

Date: 01/01/2026

Signature: _____

Client

Name: _____

Organisation: _____

Role: _____

Signature: _____

Location: _____

Date: _____